

Data Protection Impact Assessment (DPIA) — Anti-Fraud & Trust-Integrity System

Document	Anti-Fraud / Trust-Integrity DPIA
Version	1.0 (2026-07-05)
Prepared by	Setnayan Engineering
Data Controller	SETNAYAN SOFTWARE DEVELOPMENT SERVICE (sole proprietorship, PH) · proprietor Indalecio Sacdalan Casasola II · DTI BN 8297508
DPO / reviewer	Claire E. Buanhog
Status	DRAFT — awaiting DPO/counsel sign-off. System built, gated OFF in production until sign-off + owner review.
Related	Anti_Fraud_Trust_Integrity_2026-07-05.md (spec) · Anti_Fraud_DPO_Counsel_Brief_2026-07-05.md (exec summary)

Purpose of this DPIA: assess the privacy impact of processing personal data to detect and act on marketplace fraud, under the Philippine Data Privacy Act of 2012 (RA 10173) and its IRR. This is a living document; the DPO's answers in § 12 complete it.

1. Why we process this data (purpose)

Setnayan's marketplace promise is "No fakes. No pay-to-win." Vendors earn organic trust signals (badges, ratings, "Most Booked"). A dishonest vendor can attack this by (a) creating sockpuppet couple accounts to post fake 5★ reviews, or (b) self-importing fake "delivered" events to inflate booking counts. To protect couples (who rely on these signals to choose vendors) and honest vendors (who would be out-competed by fakers), we detect these patterns and act on confirmed fraud.

Purpose limitation: the data described here is used **only** for fraud detection + the resulting enforcement and audit trail. It is **not** used for marketing, advertising, ranking-for-sale, credit scoring, or any profiling unrelated to fraud.

2. Scope of processing

Three stages:

1. **Identity clustering** — grouping accounts likely controlled by the same real actor.
2. **Fraud scoring** — scoring vendors on five defined fraud patterns.
3. **Enforcement** — a reversible auto-suspend, then a human- and two-admin-gated permanent ban, with an audited evidence trail and an appeal route.

3. Data inventory

Data element	Category	Source table	Used for
<code>user_id</code>	Identifier	<code>users</code>	Keying all analysis
<code>device_hash</code>	Device identifier (hashed)	<code>user_devices</code>	Same-device account linkage
<code>address_normalized</code>	Contact data	<code>users</code>	Same-address account linkage
Payment sender reference	Financial identifier	<code>payments.reference_number</code>	Same-payer account linkage
Account/review/event timestamps	Activity metadata	<code>users</code> , <code>vendor_reviews</code> , <code>event_vendors</code>	Velocity + isolation + shape scoring
Booking source + payment-reconciled flag	Transaction metadata	<code>event_vendors</code> , <code>payments.status</code>	Import-spike scoring

Explicitly NOT processed: biometric/face data, chat or message content, contact lists, precise geolocation/IP (IP is not captured today), any special-category data. Only the vendor's self-stated city is used, and only for their own listing — not in clustering.

4. Necessity & proportionality

- **Necessity:** fraud that fakes identity can only be detected by linking the signals a single actor shares across accounts (device, address, payer). No less-intrusive method reliably distinguishes ten real couples from one actor with ten accounts.
- **Proportionality / data minimization:** we use the **minimum** set of signals needed (three linkage signals + activity metadata already collected for the service). We did **not** add new collection (e.g. IP capture was considered and deliberately deferred). Clustering outputs a group id, not a dossier.
- **Effectiveness:** the same signals materially raise the cost of faking, which is the objective.

5. Lawful basis (RA 10173)

Proposed basis: **legitimate interests** of the controller and third parties (protecting couples from deception and honest vendors from unfair competition; protecting platform integrity) — RA 10173 § 12(f) analog — supported by the **contractual** anti-fraud terms every vendor agrees to.

Balancing test (controller interest vs. data-subject rights):

- *Interest:* preventing consumer deception + marketplace fraud — a substantial, legitimate interest.
- *Necessity:* see § 4 — no less-intrusive alternative.
- *Impact on the subject:* low for honest users (their data sits in a service-role-only store, never surfaced); the meaningful impact (suspension/ban) falls on those the evidence indicates are committing fraud, and is appealable with human review.
- *Reasonable expectations:* users of a reviews marketplace reasonably expect the operator to police fake reviews.
- *Safeguards:* § 8 (extensive). → **Preliminary conclusion:** legitimate interest is appropriate. **DPO to confirm** whether an explicit privacy-notice clause and/or T&C update is required (§ 12 Q1, Q3).

6. Data-subject rights

- **Access / rectification:** users retain normal rights over their own account data; the derived cluster/score is internal fraud-prevention data (RA 10173 allows limits where disclosure would prejudice fraud prevention — DPO to confirm the boundary).
- **Erasure:** honoured for account data; the **evidence snapshot on a confirmed-fraud account is retained** for the appeal window + audit/legal-defence (retention in § 10, DPO to set — § 12 Q4).

- **Object / contest:** a suspended or banned vendor may **appeal via a help-center ticket** for human re-review (§ 8, § 12 Q5).

7. Automated decision-making

Two-stage, deliberately designed so the *serious* action is never automated:

- **Auto-suspend (automated, reversible):** at a high, corroborated confidence score, the system hides the vendor's profile and freezes their badges. **No data is destroyed.** **Fully reversible** by one admin. Config (safe setting): fires only at combined score ≥ 95 **AND** ≥ 2 **distinct corroborating signals**, so no single heuristic can auto-suspend a legitimate vendor.
- **Permanent wipe + ban (NOT automated):** requires a human admin to initiate with a typed confirmation **and** a *second* admin's approval (four-eyes), producing an audited evidence snapshot. Never triggered by the algorithm alone. → Because the irreversible measure is human-and-four-eyes-gated, and the automated measure is reversible with a human appeal, we assess this as consistent with RA 10173's safeguards on automated processing. **DPO to confirm** (§ 12 Q2).

8. Technical & organizational safeguards (built)

- **Access control — service-role only.** `identity_clusters`, `user_identity_signals`, `fraud_signals`, `vendor_fraud_scores`, `fraud_enforcement_audit` all carry RLS that **revokes all access from anon and authenticated**. No vendor or couple can ever read cluster membership or scores. Only server/admin roles read them.
- **Purpose limitation** enforced by isolation from marketing/ranking systems.
- **Data minimization** (§ 4).
- **Human-in-the-loop** for irreversible action + **two-admin approval**.
- **Full audit trail:** every enforcement action (`auto_suspend`, `unsuspend`, `dismiss`, `ban_wipe`) is logged with actor, reason, and evidence snapshot in `fraud_enforcement_audit`.
- **Appeal mechanism** via the help-center ticket queue.
- **Reversibility by design:** suspension destroys nothing; only a human-confirmed ban is irreversible.

9. Data flow (summary)

Existing service data (accounts, reviews, bookings, payments) → SQL views compute identity clusters + fraud signals within the production database → scores written to `fraud_signals` / `vendor_fraud_scores` (service-role only) → admin console reads scores

for the fraud queue → admin action writes to `fraud_enforcement_audit` . **No data leaves the production database** (Supabase, Singapore) and **nothing is shared with third parties**.

10. Retention (proposed — DPO to confirm, § 12 Q4)

Data	Proposed retention
Identity clusters / signals for active, unflagged users	Recomputed continuously; no separate long-term store beyond current state
<code>fraud_signals</code> (open/dismissed)	Proposed: 12 months, then purge
Evidence snapshot on a confirmed-fraud / banned account	Proposed: retain for the appeal window + audit/legal-defence (e.g. 24 months), then purge

11. Risk register

Risk	Likelihood	Impact	Mitigation	Residual
False auto-suspend of a legitimate vendor	Low	Medium (reversible)	≥95 score + ≥2-signal guard; instant admin un-suspend; appeal	Low
Wrongful permanent ban	Very low	High (irreversible)	Human + two-admin gate; typed confirmation; evidence snapshot; appeal	Low
Cluster data exposed to a vendor/couple	Very low	High	Service-role-only RLS; no UI ever surfaces it	Very low
Purpose creep (fraud data reused for ads/ranking)	Low	Medium	Purpose-limitation policy; system isolation	Low
Over-collection	Low	Medium	Minimization; IP deliberately not captured	Low

12. DPO / counsel sign-off

*To be completed by the Data Protection Officer, **Claire E. Buanhog**. For each item, tick your decision and use the line beneath it for any conditions or notes.*

1. Lawful basis — Is legitimate interest the correct basis, or is explicit consent / a specific privacy-notice + Terms clause required?

☐ Approved — legitimate interest ☐ Requires consent / disclosure ☐ Approved with conditions

2. Automated measure — Is the reversible auto-suspend acceptable, given the permanent wipe/ban is human- and two-admin-gated?

☐ Approved ☐ Not approved ☐ Approved with conditions

3. Disclosure — Must the anti-fraud processing be described in the privacy notice / vendor Terms? *(If yes, engineering will draft the clause for your approval.)*

☐ Yes — disclosure required ☐ No ☐ Conditions

4. Retention — Confirm or adjust the periods proposed in § 10.

Fraud signals: _____ Banned-account evidence:

5. Appeal sufficiency — Is a help-center ticket + human re-review an adequate right to contest?

☐ Approved ☐ Not adequate ☐ Conditions

6. Other conditions for go-live

Confirmation

I have reviewed this Data Protection Impact Assessment and confirm the decisions recorded above.

Name (printed)

Date

Signature

Position

Data Protection Officer, Setnayan

Go-live gate: no part of this system is enabled in production until this § 12 is completed and signed, and the owner has reviewed the enforcement surface.